

ESERCIZIO PHISHING CAMPAIGN

Obiettivo: Progettare una campagna di phishing o uno spear phishing credibile con l'ausilio dell'intelligenza artificiale verso un target a vostra scelta.

Creazione di una mail di spear phishing realistica tramite uso di AI:

- Come primo passo, un attaccante potrebbe utilizzare tecniche di OSINT passivo per raccogliere informazioni pubbliche sull'azienda target. L'obiettivo sarebbe individuare figure interne, ruoli aziendali, indirizzi email, reparti amministrativi e possibili dipendenti autorizzati a gestire pagamenti o informazioni sensibili.
- Successivamente, l'attaccante potrebbe costruire una comunicazione apparentemente proveniente da una figura autorevole dell'azienda, ad esempio il responsabile della direzione amministrativa. La credibilità del messaggio potrebbe essere aumentata tramite spoofing del mittente oppure tramite tecniche di typosquatting o omograph attack. Ad esempio, al posto del dominio legittimo novatech.com, potrebbe essere utilizzato un dominio simile come novotech.com, oppure un dominio contenente caratteri visivamente simili appartenenti ad altri alfabeti.
- Per rendere la mail più credibile sono state considerate alcune tecniche persuasive descritte da Robert Cialdini, in particolare autorità e urgenza. L'autorità deriva dal fatto che il messaggio sembra provenire da un responsabile aziendale, mentre l'urgenza viene creata tramite una scadenza ravvicinata per l'esecuzione del pagamento.
- In una frode di questo tipo, l'attaccante dovrebbe indicare coordinate bancarie effettivamente raggiungibili. La mancata corrispondenza tra beneficiario, fornitore abituale e IBAN rappresenta un importante indicatore di rischio. Per questo motivo, in caso di nuovo beneficiario, nuovo IBAN o richiesta urgente fuori procedura, il pagamento dovrebbe essere sempre verificato tramite un canale alternativo e approvato secondo le procedure aziendali.

Esempio simulazione di mail di spear phishing:

Da: Marco Rinaldi <marco.rinaldi@novotech.com>

A: Laura Conti <laura.conti@novotech.com>

Oggetto: URGENTE - Disposizione pagamento fornitore entro le 16:30

Buongiorno Laura,

ti scrivo perché è necessario predisporre con urgenza il pagamento relativo alla pratica fornitore NVT-2026/184.

La direzione ha approvato la chiusura della posizione e il pagamento deve essere inserito entro le 16:30 di oggi, così da evitare il blocco della fornitura prevista per domani mattina.

Di seguito i dati della disposizione:

Importo: 18.740,00 €

Beneficiario: AlfaServizi Cloud S.r.l.

IBAN: FK00 7373 2309 1953 2344 123

Causale: Saldo pratica NVT-2026/184

Ti chiedo di darmi conferma appena la disposizione viene inserita.

Sarò in riunione fino alle 18:00 e potrei non riuscire a rispondere prima di allora. Appena la disposizione è stata inserita, inviami comunque la conferma: la controllerò appena possibile.

Grazie,

Marco Rinaldi

Direzione Amministrativa

NovaTech S.r.l.

Elementi sospetti principali:

- richiesta di pagamento urgente;
- pressione temporale con scadenza;
- dominio email simile ma non identico a quello aziendale;
- richiesta di conferma nonostante il mittente dichiara di non poter rispondere;
- beneficiario e IBAN da verificare rispetto allo storico fornitori;
- assenza di una normale procedura di doppia approvazione.

Per contrastare questo tipo di attacchi, sarebbe necessario attuare una corretta procedura difensiva che potrebbe prevedere: il controllo del dominio del mittente, la verifica dell'IBAN e del beneficiario, il confronto con lo storico dei fornitori e la conferma della richiesta tramite un canale alternativo, ad esempio telefono aziendale o piattaforma interna.